LEZIONE 04

Come si svolge davvero un attacco

Un attacco non è una cosa che succede in un momento. Passa da una serie di fasi, e se ne fermi una si ferma tutto. Qui ci sono le fasi e i nomi con cui le trovi scritte.

A COLPO D'OCCHIO



Sette fasi in sequenza. Fermarne una qualsiasi interrompe l'attacco.

La mappa degli attacchi: MITRE ATT&CK

MITRE ATT&CK è un catalogo delle tattiche e delle tecniche che gli attaccanti usano davvero, raccolte da attacchi osservati sul campo. Due parole da sapere:

- **Tattica (Tactic):** l'obiettivo di un passo, il *perché*: per esempio restare sulla macchina (*Persistence*), ottenere più permessi (*Privilege Escalation*), portare fuori i dati (*Exfiltration*). Ha un codice come `TA0004`.
- **Tecnica (Technique):** il modo concreto, il *come*: per esempio un'attività pianificata (*Scheduled Task*) o il furto di credenziali dal dominio (*Kerberoasting*). Ha un codice come `T1053`.

> La tattica è il perché, la tecnica è il come. ATT&CK serve a chi difende, e a chi simula gli attacchi per mestiere, per parlare la stessa lingua e trovare i buchi.

Le fasi di un attacco: la Cyber Kill Chain

La **Cyber Kill Chain** è un modello ideato da Lockheed Martin: descrive un attacco in sette fasi, una dopo l'altra. Tra parentesi il nome con cui le trovi scritte.

1. **Ricognizione** *(Reconnaissance)* — raccolta di informazioni sul bersaglio.

2. **Preparazione** *(Weaponization)* — costruzione dell'arma, per esempio un documento con una macro.
3. **Consegna** *(Delivery)* — l'arma arriva: per mail, su una chiavetta USB, da un sito.
4. **Sfruttamento** *(Exploitation)* — l'arma sfrutta una vulnerabilità, o un clic.
5. **Installazione** *(Installation)* — sul computer resta un programma che dà accesso da fuori.
6. **Comando remoto** *(Command and Control, C2)* — chi attacca comanda il computer da remoto.
7. **Obiettivo** *(Actions on Objectives)* — lo scopo finale: furto di dati, cifratura, frode.

> **L'idea per chi difende:** basta interrompere una sola fase per fermare l'attacco. La Kill Chain dice in che ordine succedono le cose; ATT&CK dice, per ogni fase, in quali modi.

I rischi delle applicazioni web: OWASP Top 10

La **OWASP Top 10** è l'elenco dei dieci rischi di sicurezza più gravi delle applicazioni web, aggiornato ogni pochi anni dalla comunità OWASP. Alcuni ricorrono sempre: controlli di accesso sbagliati (*Broken Access Control*), iniezioni di codice (*Injection*, come la SQL injection e l'XSS), configurazioni sbagliate (*Security Misconfiguration*), componenti vecchi e vulnerabili (*Vulnerable Components*). È il punto di partenza per chi sviluppa o mette alla prova un portale web.

Un esempio: un ransomware, fase per fase

È la storia che sento raccontare più spesso, con piccole varianti. Tra parentesi il codice ATT&CK della tecnica: è lo stesso che poi ritrovi scritto negli avvisi degli strumenti.

1. **Ricognizione.** Sul sito dell'azienda c'è l'indirizzo email dell'amministrazione. Su LinkedIn c'è il nome del titolare. Basta questo.
2. **Preparazione.** Un documento Excel con una macro che scarica un programma.
3. **Consegna.** Una mail all'amministrazione, «fattura in scadenza», a nome di un fornitore vero. *(T1566.001 — allegato di phishing)*
4. **Sfruttamento.** Un collega apre il file e abilita la macro, perché Excel gliel'ha chiesto. *(T1204.002 — esecuzione da parte dell'utente)*
5. **Installazione.** Sul PC compare un programma di accesso remoto, che riparte a ogni accensione. Da fuori, da quel momento, qualcuno è dentro. *(T1053.005 — attività pianificata)*
6. **Comando remoto.** Il PC parla con un server esterno ogni pochi minuti. Nessuno lo vede, perché nessuno guarda il traffico in uscita. Passano giorni o settimane: intanto cercano le password e arrivano ai server. *(T1071 — protocollo applicativo per il comando remoto)*
7. **Obiettivo.** Una notte di sabato partono la copia dei dati verso l'esterno *(T1041 — esfiltrazione)* e poi la cifratura *(T1486 — cifratura per estorsione)*. Il backup era raggiungibile dalla rete: cifrato anche quello.

> Questi sei codici non sono da imparare a memoria: servono a mostrare che «T1486» in un avviso vuol dire «siamo alla fase 7, stanno cifrando». Con il codice vai su attack.mitre.org e sai esattamente a che punto sei.

Dove si poteva fermare

Fase	Cosa l'avrebbe fermata	Costo
3 · Consegna	filtro sulla posta che blocca gli allegati con macro	basso
4 · Sfruttamento	macro disabilitate da criterio di gruppo, non a scelta dell'utente	zero
5 · Installazione	utenti senza diritti di amministratore sul proprio PC	zero
6 · Comando remoto	guardare il traffico in uscita; un PC che parla ogni cinque minuti con un indirizzo mai visto si nota	medio
6 · Movimento interno	rete divisa in zone (lezione 9) e password diverse fra PC e server	medio
7 · Obiettivo	un backup che dalla rete non si può né vedere né cancellare	basso

Ne bastava una. Le due a costo zero sono la seconda e la terza riga: macro e diritti di amministratore.

Le stesse fasi, con le falle di queste settimane

Il modello non è teoria vecchia. Le fasi sono quelle degli attacchi di ottobre 2026, e ce ne sono due che ogni informatico da solo dovrebbe conoscere, perché non passano dalla mail: passano da qualcosa che è già esposto a internet.

PHP2Shell (CVE-2026-109618 e CVE-2026-109619, 21 ottobre 2026). Due falle critiche nel cuore di PHP: chi le sfrutta esegue codice sul server **senza doversi autenticare**. Colpiscono qualunque sito che gira in PHP, in tutti i modi con cui un server lo manda in esecuzione (mod_php, PHP-FPM, php-cgi): quindi gran parte di WordPress, Drupal, Joomla e dei gestionali web. Nella Kill Chain saltano le prime quattro fasi in un colpo: niente mail, niente macro, nessun collega che deve cliccare. Basta che il sito sia raggiungibile. Si chiudono aggiornando a PHP 8.2.35 / 8.3.36 / 8.4.27 / 8.5.12; la 8.1 e le precedenti sono a fine supporto (EOL, lezione 2) e la correzione non arriva.

> **E qui torna la lezione 2.** Su RHEL, AlmaLinux, Rocky e Oracle Linux il numero di versione che il server dichiara **non cambia** nemmeno dopo la correzione: il fornitore la applica «all'indietro» sulla sua release (backport). Lo scanner che guarda solo quel numero ti dirà «vulnerabile» quando non lo sei più — o il contrario. La versione vera si legge dal feed del tuo fornitore o, sull'host, con `dnf updateinfo list --cve`. La domanda è quella di allora: la versione è la mia?

Un apparato di bordo nel KEV. La porta d'ingresso più comune non è nemmeno la mail: è un apparato esposto — VPN, firewall, gateway — con una falla già nel catalogo KEV (lezione 3). È la fase di consegna servita su un piatto, perché l'apparato è fatto apposta per stare esposto: se non è aggiornato è una porta aperta che nessun antivirus sui PC vede. Ogni mese ne compaiono di nuovi nel KEV, e sono quelli che gli attaccanti provano per primi.

Due esempi, una morale: le fasi che quasi nessuno guarda — un servizio web esposto, un apparato di bordo dimenticato — sono quelle da cui si entra davvero.

Gli errori che vedo più spesso

- **Difendere solo la consegna.** Antivirus e filtro posta, e basta. Se passano quelli, dalla fase 5 in poi non c'è nessuno.
- **Non guardare mai il traffico in uscita.** Il firewall ferma quello che entra; quello che esce di solito passa tutto. La fase 6 vive lì.
- **Backup raggiungibile dalla rete** con le stesse credenziali di tutto il resto.

Come lo verifichi

Per ognuna delle sette fasi scrivi una riga: «qui lo vedrei con…» oppure «qui non lo vedrei». Dove scrivi la seconda, hai trovato il lavoro delle prossime settimane. Le righe vuote sono quasi sempre la 6 e la 7.

CON L'AI, PER QUESTA LEZIONE

Uso 4 di 12 · L'assistente come banco di prova. Due mosse, lo stesso assistente: prima gli fai condurre un'esercitazione di incidente, poi gli fai leggere se una falla di oggi ti riguarda davvero. In nessuna delle due inventa lo scenario: glielo dai tu, con quello che hai preparato nelle lezioni precedenti.

A · L'esercitazione da tavolo. Le grandi aziende provano gli incidenti a tavolino, con un conduttore che tira fuori le sorprese. Da soli non si può; con l'assistente sì: lui fa il conduttore, tu rispondi come risponderesti davvero.

Ti servono due cose. Il foglio della lezione 1, con i cinque sistemi senza i quali l'azienda si ferma e cosa conta di più per ciascuno. E il `da_fare.csv` della lezione 3: le prime righe, quelle KEV su apparati esposti, sono la porta d'ingresso più probabile, spesso più della mail. All'assistente vanno i nomi dei prodotti e i codici CVE, come sempre senza indirizzi né password.

> Conduci un'esercitazione su un incidente informatico in un'azienda di [N] persone. Questi sono i sistemi senza i quali l'azienda si ferma, con cosa conta di più per ciascuno: [incolla il foglio della lezione 1]. Queste sono le vulnerabilità ancora aperte, con prodotto, se è esposto a internet e se è nel KEV: [incolla le prime righe di da_fare.csv]. Scegli tu da dove entra l'attaccante, senza dirmelo: una mail di phishing aperta dall'amministrazione, una delle vulnerabilità del mio elenco, oppure un sito PHP esposto con PHP2Shell (CVE-2026-109618). Vai avanti una fase alla volta seguendo la Cyber Kill Chain. A ogni fase descrivi cosa vedo io, l'unico informatico, e fermati: aspetta la mia risposta, poi dimmi cosa succede di conseguenza. Sii realistico sui tempi. Alla fine dimmi da dove sei entrato, in quali fasi avrei potuto accorgermene prima e con cosa, e per ogni fase il codice della tecnica ATT&CK che hai usato.

Ci vogliono venti minuti e si scopre sempre qualcosa: di solito che non si sa chi chiamare, o che il backup non è dove si pensava. Se è entrato da PHP2Shell o da una riga del `da_fare.csv`, quella porta va chiusa questa settimana. I codici ATT&CK della fine controllali su attack.mitre.org: se un codice non esiste, l'assistente l'ha inventato. Quelli veri li ritroverai negli avvisi degli strumenti, e saprai a che fase sei.

B · Fatti leggere la versione vera, non il banner. Finita l'esercitazione, resta la domanda pratica: PHP2Shell mi riguarda? Qui l'assistente serve per non ricadere nella trappola della lezione 2. La domanda non è «che versione dichiara il server», è «il mio pacchetto ha già la correzione». Su RHEL, AlmaLinux, Rocky e Oracle Linux il numero non si muove, perché la correzione è in backport: la risposta sta nel changelog del pacchetto e nell'avviso del tuo fornitore, non nel banner.

Raccogli tu l'evidenza vera sull'host e passagliela — niente banner, niente indirizzi:

`rpm -q php · dnf updateinfo list --cve CVE-2026-109618 · rpm -q --changelog php | head -20`

> Il server gira [AlmaLinux 9 / Rocky 9 / Oracle Linux 9]. Il pacchetto installato è [incolla l'output di `rpm -q php`]. Questo è l'output di `dnf updateinfo list --cve CVE-2026-109618` e questo il changelog del pacchetto: [incolla]. Dimmi se CVE-2026-109618 risulta già corretta sul mio sistema, ragionando sul changelog e sull'avviso del fornitore e **non** sul numero di versione (la correzione è in backport). Se non risulta corretta, dimmi il comando per aggiornare solo questo pacchetto.

Una cosa da sorvegliare: se l'assistente risponde «la tua 8.2.20 è più vecchia della 8.2.35, quindi sei vulnerabile», ti ha appena rifatto l'errore del banner. Correggilo: la prova è il changelog e l' `updateinfo` , non il confronto fra numeri. L'ultima parola resta del feed del fornitore; l'assistente, qui, è solo chi te lo legge in fretta. Lo stesso schema vale per qualsiasi software su queste distribuzioni, non solo per PHP.

DA FARE

Lunedì mattina, se sei l'unico informatico

1. Prendi l'ultima mail di phishing arrivata in azienda e guarda in quale delle sette fasi si è fermata. E chi l'ha fermata: il filtro, un collega, nessuno. ☐
2. Chiediti quale fase oggi non vedresti. Per molti è la sesta, il computer infetto che parla con l'esterno. ☐
3. Non serve presidiarle tutte. Scegli quella che ti costa meno e parti da lì. ☐

Glossario

Le sigle nuove di questa lezione, con due righe ciascuna: la prima per capirsi, la seconda per capire. Poi, in breve, quelle delle lezioni precedenti.

ATT&CK NUOVA — Il catalogo, tenuto da MITRE, delle tattiche e tecniche che gli attaccanti usano davvero. *Per capirla meglio:* Le tattiche sono gli obiettivi (restare sulla macchina, ottenere più permessi, portare fuori i dati), le tecniche sono i modi concreti. Serve a difensori e strumenti per parlare la stessa lingua: quando un avviso dice «T1053», sta dicendo «attività pianificata usata per restare sulla macchina».

TA0004, T1053 NUOVA — I codici delle tattiche (TA) e delle tecniche (T) nel catalogo ATT&CK. *Per capirla meglio:* TA0004 è la tattica «Privilege Escalation», ottenere più permessi; T1053 è la tecnica «Scheduled Task/Job», usare le attività pianificate per eseguire qualcosa. Li trovi negli avvisi dei sensori e degli antivirus: con il codice risali alla pagina di ATT&CK che spiega cosa è successo e come si cerca.

C2 NUOVA — Il canale con cui chi attacca comanda da remoto un computer infetto (Command and Control). *Per capirla meglio:* Dopo l'infezione il PC «chiama casa» a intervalli regolari e riceve ordini. È la fase in cui l'attaccante resta dentro per giorni o settimane. Si vede guardando il traffico in uscita: un PC che parla ogni pochi minuti con un indirizzo mai visto. È la fase che quasi nessuno guarda.

OWASP NUOVA — Una comunità mondiale che pubblica materiale gratuito sulla sicurezza delle applicazioni web (Open Web Application Security Project). *Per capirla meglio:* La sua «Top 10» è l'elenco dei dieci rischi più comuni dei siti e dei portali. Se la tua azienda ha un portale fatto da un fornitore, chiedergli come si posiziona rispetto alla OWASP Top 10 è una domanda che capisce.

USB NUOVA — La presa a cui si attaccano chiavette, mouse, tastiere (Universal Serial Bus). *Per capirla meglio:* Nella sicurezza compare per due motivi: una chiavetta trovata può contenere un programma che parte da solo, e dalla USB si copiano fuori i dati. Le chiavette trovate si portano all'informatico, non si inseriscono.

RCE NUOVA — Esecuzione di codice da remoto: la falla più grave, perché chi la sfrutta fa girare i propri comandi sul tuo server (Remote Code Execution). *Per capirla meglio:* È quello che fanno PHP2Shell e gran parte delle falle degli apparati di bordo. Quando è «non autenticata» vuol dire che l'attaccante non ha bisogno di una password: gli basta raggiungere il servizio. Per questo le RCE su cose esposte a internet si chiudono per prime.

RHEL NUOVA — La versione «aziendale» di Red Hat Linux, diffusissima nei server; AlmaLinux, Rocky Linux e Oracle Linux ne sono cloni compatibili (Red Hat Enterprise Linux). *Per capirla meglio:* Su queste distribuzioni le correzioni di sicurezza arrivano «in backport»: il fornitore le applica sulla sua release del pacchetto lasciando invariato il numero di versione a monte. È il motivo per cui il banner mente, ed è dove serve la mossa B di questa lezione: guardare il changelog e l' `updateinfo`, non il numero.

Dalle lezioni precedenti (la spiegazione completa è nella lezione in cui sono comparse):

CIA — Le tre cose da proteggere: riservatezza, integrità, disponibilità (in inglese Confidentiality, Integrity, Availability). Niente a che vedere con l'agenzia americana. *(lezione 1)*

ransomware — Un programma che cifra i file dell'azienda e chiede un riscatto per la chiave. Non è una sigla, ma è la parola che torna più spesso. *(lezione 1)*

DDoS — Attacco che manda a un servizio più richieste di quante ne regga, finché smette di rispondere. Sta per Distributed Denial of Service. *(lezione 1)*

HTTPS — La versione cifrata di HTTP, il protocollo delle pagine web. È il lucchetto nel browser. *(lezione 1)*

PLC — Il computer industriale che comanda una macchina o una linea di produzione (Programmable Logic Controller). *(lezione 1)*

IBAN — Il codice del conto corrente, quello che si scrive per fare un bonifico (International Bank Account Number). *(lezione 1)*

AI — Intelligenza artificiale. Qui vuol dire gli assistenti con cui si parla scrivendo, e i modelli che ci stanno dietro. *(lezione 1)*

CVE — Il codice univoco di una vulnerabilità nota, nel formato CVE-anno-numero (Common Vulnerabilities and Exposures). *(lezione 2)*

CPE — Il nome standard di un prodotto e di una versione, usato dall'NVD per dire cosa colpisca un CVE (Common Platform Enumeration). *(lezione 2)*

CWE — La categoria di una debolezza del software, per esempio «SQL injection» (Common Weakness Enumeration). *(lezione 2)*

CVSS — Il punteggio di gravità di una vulnerabilità, da 0 a 10 (Common Vulnerability Scoring System). *(lezione 2)*

NVD — La banca dati pubblica dei CVE, gestita dal NIST americano (National Vulnerability Database). *(lezione 2)*

EOL — Fine del supporto di un prodotto: il produttore non pubblica più correzioni, nemmeno di sicurezza (End Of Life). *(lezione 2)*

PoC — Il codice, o la procedura, che dimostra che una falla si può sfruttare davvero (Proof of Concept). *(lezione 2)*

NIST — L'ente americano degli standard (National Institute of Standards and Technology). Gestisce l'NVD e pubblica le linee guida più usate. *(lezione 2)*

CNA — Gli enti autorizzati ad assegnare i codici CVE: grandi produttori, CERT nazionali, ricercatori accreditati (CVE Numbering Authority). *(lezione 2)*

MITRE — L'organizzazione americana senza scopo di lucro che coordina i CVE e gestisce ATT&CK. *(lezione 2)*

CERT — Una squadra che risponde agli incidenti informatici, nazionale o di settore (Computer Emergency Response Team). *(lezione 2)*

EPSS — Una stima, in percentuale, della probabilità che una vulnerabilità venga sfruttata nei prossimi trenta giorni (Exploit Prediction Scoring System). *(lezione 2)*

AV, AC, PR, UI — Le quattro lettere principali del vettore CVSS: da dove si attacca, quanto è difficile, se servono privilegi, se serve un'azione dell'utente. *(lezione 2)*

SQL — Il linguaggio con cui si interrogano le banche dati (Structured Query Language). *(lezione 2)*

XSS — Un difetto di un sito che permette di far eseguire del codice nel browser di chi lo visita (Cross-Site Scripting). *(lezione 2)*

VPN — Un collegamento cifrato da fuori verso la rete aziendale, come se si fosse in ufficio (Virtual Private Network). *(lezione 2)*

NAS — Un disco di rete condiviso, spesso usato per i file e per i backup (Network Attached Storage). *(lezione 2)*

API — Un modo per far parlare due programmi fra loro, senza passare da una pagina web (Application Programming Interface). *(lezione 2)*

KEV — Il catalogo delle vulnerabilità che vengono già sfruttate in attacchi reali, tenuto da CISA (Known Exploited Vulnerabilities). *(lezione 3)*

CISA — L'agenzia americana per la sicurezza informatica e delle infrastrutture (Cybersecurity and Infrastructure Security Agency). *(lezione 3)*

FIRST — L'associazione mondiale delle squadre di risposta agli incidenti, che calcola e pubblica l'EPSS (Forum of Incident Response and Security Teams). *(lezione 3)*

CSV — Un file di testo con i dati in colonne separate da virgole (Comma-Separated Values). Si apre con un foglio di calcolo. *(lezione 3)*

Ing. Alessandro Manneschi
Cyber Security Architect · NIS2, monitoraggio e sicurezza per le PMI

Tutte le lezioni, gratis:
github.com/alevento/sicurezza-per-chi-e-solo
Licenza CC BY-NC-SA 4.0